

Cybersecurity Incident Report

Section 1: Identify the type of attack that may have caused this network interruption

One potential explanation for the website's connection timeout error message is that the web server crashed due to a direct Dos Syn flood attack, The logs show that an employee visitor with the IP address of 198.51.100.14 successfully completes a SYN/ACK connection handshake with the webserver (log item nos. 47, 48, 49). Then, the employee's browser requests the sales.html webpage with the GET command and the web server responds (log item no. 50 and 51) granting the employee access to the website. Right after, the attacker with IP address 203.0.113.0 completes a SYN/ACK connection handshake with the web server (log item nos. 52, 53, 54) , followed by another employee visiting the website from IP address 198.51.100.14 (log item nos. 55, 56, 58, 60, 62) who was also successful. After the web server responded to the second employee's initial request with a SYN, ACK packet during the handshake process(log item no.55 and 56) , the attacker started flooding the web server with additional SYN packets (log item no. 57, 59, 61). This was followed by a third employee trying to access the website from IP address 198.51.100.5 (log item no. 63, 65, 67) completing the initial SYN/ACK handshake. After the handshake, the third employee's browser sends a packet requesting the sales.html webpage using HTTP protocol (log item no. 71) , a fourth employee from 198.51.100.16 then also sends a connection request (log item no. 69, 73) You can see the web server start to show signs that it is overloaded due to the SYN flood attack at this point because the fourth employee is sent a RST/ACK packet and no connection was established with the web server (log item no. 73). This is followed by a fifth visitor from IP address 198.51.100.7 (log item no.75) with a SYN packet.The third employee is then sent an HTTP gateway time-out error message response in TCP(log item no. 77) next, a sixth visitor from IP address 198.51.100.22 (log item no.79) sends the web server a SYN packet.The fifth employee is then sent a RST/ACK response (log item no. 80)followed by the sixth employee(log item no.85) and then the fourth employee receives the same RST/ACK error response(log item no. 92)Finally a seventh employee makes a connection attempt from IP address 198.51.100.9(log item no.97)and receives the last RST/ACK(log item no. 127) from then on the only traffic logged is SYN packets being sent repeatedly from the same IP address.

Section 2: Explain how the attack is causing the website to malfunction

- The [SYN] packet is the initial request from an employee visitor trying to connect to a web page hosted on the web server. SYN stands for "synchronize."

- The [SYN, ACK] packet is the web server's response to the visitor's request agreeing to the connection. The server will reserve system resources for the final step of the handshake. SYN, ACK stands for "synchronize acknowledge."
- The [ACK] packet is the visitor's machine acknowledging the permission to connect. This is the final step required to make a successful TCP connection. ACK stands for "acknowledge."

When the amount of SYN packets sent is greater than the server resources available to handle the requests, the server will become overwhelmed and unable to respond to the requests. This is a network level denial of service (DoS) attack, called a SYN flood attack, that targets network bandwidth to slow traffic. A SYN flood attack simulates a TCP connection and floods the server with SYN packets. A DoS direct attack originates from a single source. A distributed denial of service (DDoS) attack comes from multiple sources, often in different locations, making it more difficult to identify the attacker or attackers.

Initially, the attacker's SYN request is answered normally by the web server. However, the attacker keeps sending more SYN requests, which is abnormal. At this point, the web server is still able to respond to normal visitor traffic, but the log begins to reflect the struggle the web server is having to keep up with the abnormal number of SYN requests coming in at a rapid pace. While normal traffic is trying to visit the website, the attacker is sending several SYN requests every second. A log will show failed communications between legitimate website visitors and the web server. These failed communications generate error messages. The two types of errors in the logs include:

- An HTTP/1.1 504 Gateway Time-out (text/html) error message. This message is generated by a gateway server that was waiting for a response from the web server. If the web server takes too long to respond, the gateway server will send a timeout error message to the requesting browser.
- An [RST, ACK] packet, which would be sent to the requesting visitor if the [SYN, ACK] packet is not received by the web server. RST stands for reset, acknowledge. The visitor will receive a timeout error message in their browser and the connection attempt is dropped. The visitor can refresh their browser to attempt to send a new SYN request.

As the SYN flood attack continues, the web server gradually starts delaying in response and activity to legitimate visitor traffic. The visitors receive more error messages indicating that they cannot establish or maintain a connection to the web server. Shortly thereafter, the web server stops responding. The only items logged at that point are from the attack. If there is only one IP address attacking the web server, you can assume this is a direct DoS SYN flood attack. Additionally, to prevent a direct DoS SYN flood attack, the web server's admin can configure the organization's firewall to limit incoming SYN requests and install an Intrusion Prevention System (IPS) to detect and block malicious traffic patterns.

